app跳轉webview代登機制

> 📌 **重要更新：** API 參數完全沒變，但後端服務已更新邏輯以支援第三方網域代登（解決 iOS webview 禁用第三方 cookie 的問題）。App 端無需修改程式碼。

新的跳轉方式-silent_renew

會寫入統登資訊，使用統登的機制可以取得會員資訊。

app 端跳轉網址：

https://api.cmoney.tw/identity/authorize/silent_renew?response_type=code&client_id={手機app的clientId}&code_challenge=GO6iMDCmMF3nrqmC8e23qUcKmHomPaRvkVc3fugBBiY&target_uri={跳轉的目標網址}&access_token={jwt-token,同cm_at}

參數說明：

- **redirect_uri:給統登跳轉。以前需要帶，現在可以不帶，代登服務會自動補上empty.html。**
- **access_token:** jwt token
- **target_uri:** 跳轉的目標網址
- **code_challenge:** 手機隨機產的亂數

target_uri 的處理邏輯：

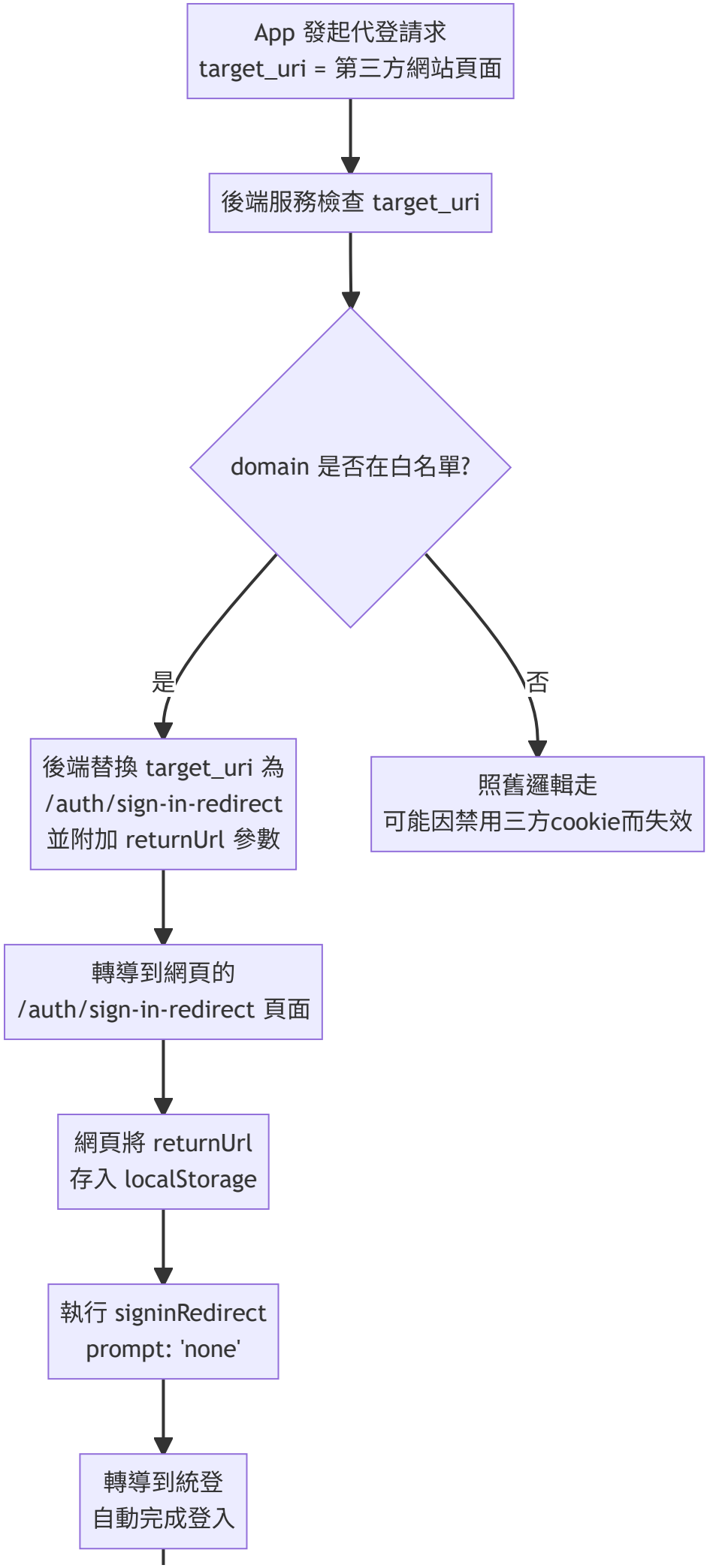
cmoney.tw 網域：

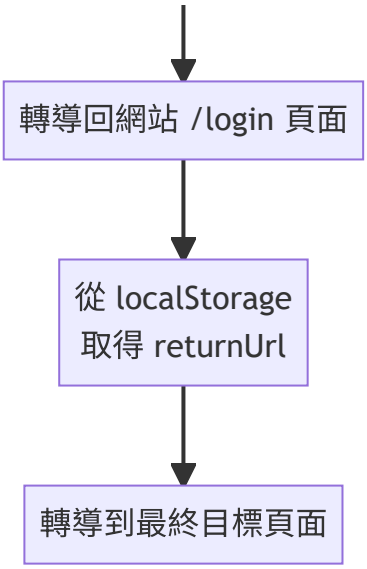
- 如果跳轉要支援www以外的網域(僅限：*.cmoney.tw)，nuxt/vue專案的統一登入需設定identityDomain(metadata資訊，除了issuer)/productionDomain(redirect uri)為動態取得目前domain，且跟服務新增申請各domain的allowedCorsOrigin、redirectUris、postLogoutUris

**第三方網域 (非 .cmoney.tw)：*

- 後端服務會檢查 target_uri 的 domain 是否在白名單中
- **若在白名單中：** 後端會自動將 target_uri 替換為對應的網頁代登處理頁面（通常是 `/auth/sign-in-redirect` ），並將原始目標頁面作為 `returnUrl` 參數附加
  - 範例： `https://cmnews.com.tw/auth/sign-in-redirect?returnUrl=https://cmnews.com.tw/article/cmoney-53004923-01a4-11f1-afed-4af6f5f30531`
- **若不在白名單中：** 照舊邏輯走，但在禁用三方cookie的狀態下會失效（原因：統登的idp僅會在.cmoney.tw下，在禁用三方cookie的狀態下，無法提供其他網域使用）。IOS的webview目前預設禁用三方cookie

第三方網域代登流程圖：


App 發起代登請求
target_uri = 第三方網站頁面
後端服務檢查 target_uri
domain 是否在白名單?
是
否
後端替換 target_uri 為
/auth/sign-in-redirect
並附加 returnUrl 參數
照舊邏輯走
可能因禁用三方cookie而失效
轉導到網頁的
/auth/sign-in-redirect 頁面
網頁將 returnUrl
存入 localStorage
執行 signinRedirect
prompt: 'none'
轉導到統登
自動完成登入



第三方網站需要的設定：

> ⚠️ **注意：未完成以下設定的第三方網站，app 代登將會失敗（iOS webview 預設禁用第三方 cookie）**

要讓第三方網站支援 app 代登，需要：

1. **新增代登處理頁面：** 在網站新增 `/auth/sign-in-redirect` 頁面
   - 該頁面需在執行 `signinRedirect` 前將 `returnUrl` 存入 localStorage
   - 執行 `signinRedirect({ prompt: 'none' })`
2. **向後端申請（必要）：**

上述跳轉網址的swagger API方法：Authorize的/authorize /silent_renew

站台端

可以使用以下方法取得token或是使用者資訊：

- 於統登拿 Token： https://outpost.cmoney.tw/identity/swagger/index.html /token
- 或單純用 token 取得使用者資訊：https://www.cmoney.tw/api/cm/profile/graphql/query/member

---

舊的跳轉方式-AccessToken

將 token 紀錄在 cookie (httpOnly，前端無法存取)。 統登資訊並不會被紀錄，新站無法使用該轉導方式。

app 端跳轉網址：

https://www.cmoney.tw/datasite/Ashx/AccessTokenLogin/AccessTokenLogin.ashx?action=login&accesstoken={accesstoken}&redirect={跳轉的目標網址}

限制：

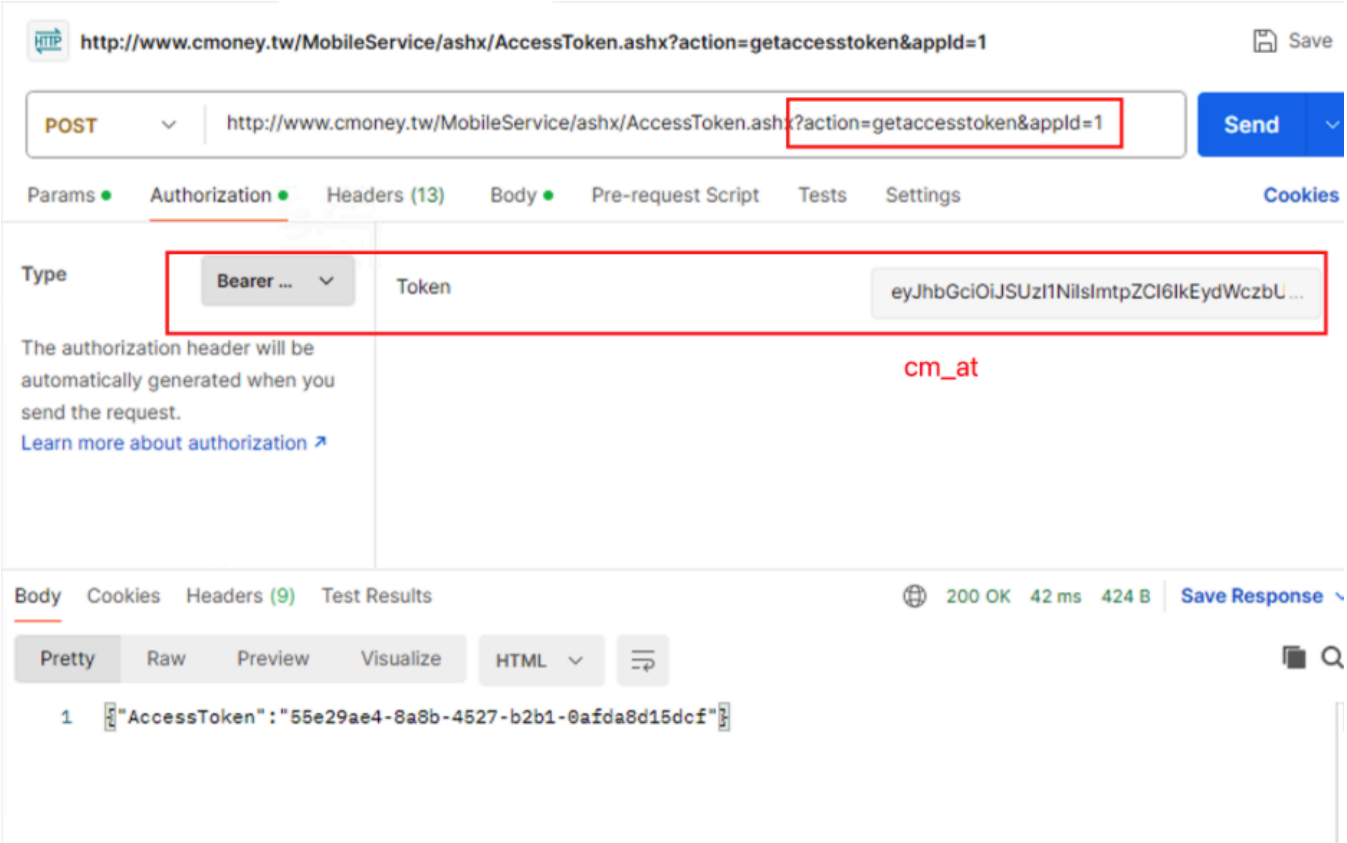
- accesstoken非站台常用的jwt token需使用以下方式取得
- 新站(直接取統登資訊的站台)無法使用該跳轉方式。

取得 Access-Token

URL：http://api.cmoney.tw/MobileService/ashx/AccessToken.ashx?action=getaccesstoken&appId=21

參數：

- action: getaccesstoken
- appId: 1
- authorization token: `Bearer {jwt token}`



限制：

- 取手機的 accessToken (只會有一次性有效而已)

測試機

用 outpost 換 accessToken，用 test 測試跳轉：
https://test.cmoney.tw/datasite/Ashx/AccessTokenLogin/AccessTokenLogin.ashx?action=login&accesstoken={accesstoken}&redirect={跳轉的目標網址}

可以使用安卓機測試 webview。

Last updated: 2026/2/4 下午5:39

Prev
新站oidc設定規範